

SQIsign v3: Specification Review Notes

Deirdre Connolly

Selkie Cryptography

durumcrustulum@gmail.com

7 September 2026 (draft for discussion)

Notes on the 1 September 2026 v3 specification, findings are ordered by assessed risk.

1 Biased interval sampling

Algorithm 4.24 and Section 4.1.4

MEDIUM

SAMPLEFROMINTERVAL sets $m = b - a + 1$ and $n = \text{ibz_bitsize}(m)$, draws an n -bit integer x , and accepts it when

$$x < m \left\lceil \frac{2^n}{m} \right\rceil.$$

The threshold is at least 2^n , so every draw is accepted. Reducing x modulo m therefore biases the output whenever m is not a power of two. For $[a, b] = [0, 2]$, the equiprobable draws 0, 1, 2, 3 produce 0, 1, 2, 0: the output probabilities are 1/2, 1/4, 1/4, rather than 1/3 each. The earlier spec review already flagged this ceiling error; the calculations below make its distributional consequences explicit.

More generally, write $R = 2^n = qm + r$, with $0 \leq r < m$. The first r residues have $q + 1$ preimages and the others have q . Their total variation distance from uniform is

$$\Delta = \frac{r(m - r)}{mR}.$$

The prose describes 64 extra random bits, which line 2 omits. Extra bits would reduce this bias, but would not fix the acceptance test.

For the EIBox values in Table 9, the coefficient draws used by Algorithm 4.78 have the following distributions before later rejections:

Level	Interval	Distance from uniform	Mean (uniform: zero)
I	$[-15, 15]$	$15/496 \approx 3.02\%$	$-15/32$
III	$[-19, 19]$	$175/1248 \approx 14.02\%$	$-175/64$
V	$[-22, 22]$	$247/1440 \approx 17.15\%$	$-247/64$

These are biases in internal draws, not measured biases in public keys or signatures. They do not describe the C reference's wider sampler either.

Why this matters to the analysis. The response path is `SIGN` $\rightarrow$ `SAMPLEQUATERNIONRESPONSE` $\rightarrow$ `RANDOMBOUNDEDELEMENT` $\rightarrow$ `SAMPLEFROMINTERVAL`. The sampler also feeds prime-norm ideal sampling and auxiliary ideal sampling through Algorithms 4.71 and 4.82.

Uniform coordinate sampling in a box enclosing a lattice ball, followed by rejection to the ball and to odd norm, gives equal weight to the accepted lattice points. Biased coordinate sampling loses that argument. The weights can depend on the chosen basis, whose representation can depend on secret ideal data. I have not established whether that dependence is visible in complete signatures; correcting the sampler restores the intended starting point for the distribution argument.

The accompanying script also gives a small $\mathbb{Z}^4$ example where odd-norm rejection and identifying v with $-v$ leave unequal weights. Those operations are therefore not a general cure for the bias, although this example is not a SQIsign response lattice.

Suggested change. Use an acceptance range whose size is divisible by m : replace the ceiling with a floor. An exact sampler is:

```
m = b - a + 1
if m == 1: return a
n = bit_length(m) + kappa
R = 2^n
limit = R - (R mod m)
repeat:
    x = uniform_n_bit_integer(prng)
until x < limit
return a + (x mod m)
```

Here $\kappa \geq 0$ changes the rejection rate, not the uniformity of accepted outputs. If approximately uniform fixed-draw sampling is preferred, I suggest specifying its statistical-distance budget and accounting for all calls and subsequent conditioning in the analysis. The prose, pseudocode, and reference should agree on which contract is intended.

This pseudocode specifies the distribution only. Public working-width bounds, observable retries, and failure handling need a separate timing argument. A fixed candidate batch with masked selection is one possible approach, provided its all-rejected probability and failure behavior are accounted for.

Reference implementation and conformance. The C reference uses a tracked bit bound plus 64 bits [2]. It adds m to the draw, checks that the sum still fits, and then reduces modulo m . In a release build the accepted sample space has size $R - m$; with assertions enabled the exceptional branch asserts. Since $R - m$ is not generally a multiple of m , this is not exact uniform sampling either, though the bias is much smaller than in the printed algorithm.

Our current Rust interval sampler already uses exact rejection over $[0, b - a]$. I suggest preserving that distribution during the port, while addressing its variable-time behavior separately. A changed random-byte schedule may require new KATs without changing the wire format or verification relation. Useful conformance cases include singleton and signed intervals, powers of two and adjacent widths, rejection boundaries, and the three EIBox intervals.

2 Hint degree weighting

Figure 4; Problem 8.1.5 and Section 8.2.2.2

Low (provisional)

In Figure 4, H_{unif} samples an odd degree $d \leq D_{\text{rsp}}$ with weight

$$\psi(d) = \prod_{\ell^e \parallel d} (\ell + 1) \ell^{e-1},$$

then samples a degree- d isogeny with non-cyclic kernels allowed. For d coprime to p , $\psi(d)$ counts cyclic kernels. Counting all degree- d kernels instead gives

$$\sigma_1(d) = \sum_{a|d} a = \prod_{\ell^e \parallel d} (1 + \ell + \cdots + \ell^e).$$

Here isogenies are counted up to isomorphism of the target, without quotienting by automorphisms of the source. Section 5.6 of the earlier security proof also identifies ψ as the cyclic count [3].

For example, degree 9 has twelve cyclic kernels and one additional kernel, $E[3]$, for a total of thirteen. Degree 25 similarly gives 30 versus 31. The printed procedure assigns an individual degree- d isogeny probability proportional to $\psi(d)/\sigma_1(d)$, which varies with d . Thus it is not uniform over all outgoing bounded odd-degree isogenies. This is a well-defined distribution, but its degree dependence needs to be reconciled with the intended comparison to H_{sim} .

The latter first chooses a target from the stationary distribution, then samples uniformly among bounded odd-degree isogenies to that target. `RANDOMBOUNDEDELEMENT` does not impose primitivity or remove odd scalar factors, so we cannot simply assume that every response is cyclic.

A statistic worth checking. Consider $3 \mid \deg(\varphi_2)$. If the response homomorphisms are uniform modulo 3 in $M_2(\mathbb{F}_3)$, this event has probability

$$\frac{\#\{M : \det M = 0\}}{3^4} = \frac{33}{81} = \frac{11}{27}.$$

The ψ -weighted degree distribution, over increasing odd-degree bounds, instead gives limiting probability $2/5$. The gap is $1/135$. The event can be checked from the degree, or from the rank of the action on 3-torsion when the hint representation makes that action available.

The missing step is a quantitative residue-distribution argument for H_{sim} at the actual joint growth of p and D_{rsp} , including target conditioning and exceptional curves. The script checks the kernel counts, the 81 small-field matrices, and finite degree-weight marginals. It does not simulate H_{sim} or prove this distinguisher.

Suggested follow-up. If the intended measure is uniform over all outgoing bounded odd-degree isogenies, I suggest investigating $\sigma_1(d)$ as the degree weight and rechecking the resulting proof distribution and its transport properties. If the ψ weights are intentional, an explanation of the degree dependence and the statistic above would help settle the question.

Theorem 8.1.7 already includes a hint-distinguishing advantage term. This observation therefore questions whether the justification makes that term small; it does not contradict the reduction as written. Nor does it refute the separate argument using the hardness of the H_{sim} -assisted relation directly. I would treat this initially as a change or clarification to the analysis. Forcing primitive or cyclic responses in the signer would be a different protocol change requiring its own analysis.

3 A few related points to make explicit

These are documented limitations or hardening suggestions, rather than new vulnerabilities found in this review.

Timing resistance. Section 8.5 already explains that signing and key generation are not fully constant-time. For a hardened version, it would help to state which widths, iteration bounds, and failure behavior are public, and which operations remain outside the timing claim. In particular, correcting interval sampling does not make `IDEALToISOGENY` or the whole signer constant-time. This needs resolution before deployment wherever the adversary can observe the relevant secret-dependent behavior.

Stronger message binding. The optional construction in Section 8.4.1 would benefit from explicit signing, verification, and encoding rules: carry the full 2λ -bit digest, use the designated λ bits for the challenge walk, and *compare all 2λ bits* during verification. Checking only the walk bits would discard the extra binding. This adds 16, 24, or 32 bytes at levels I, III, or V. Any incompatible profile needs a distinct format identifier and test vectors, including rejection when only the extra digest bits are changed.

As Section 8.4.2 explains, the auxiliary-isogeny representation remains malleable. The extended digest does not provide strong unforgeability, and matrix normalization does not make complete signatures unique.

Verifier preconditions and failure behavior. Section 3.1.2 already requires $A^2 \neq 4$ for `ECCurve`, and the C verifier checks the public and auxiliary coefficients before reconstructing bases [4]. I suggest making that checked decoding boundary explicit in Algorithm 3.24, along with propagation of supporting-routine failures to rejection. Similarly, map each deferred torsion, independence, kernel, and splitting check to the operation that enforces it. The inspected gluing code does check torsion and independence [5]; I have not established the suspected missing odd-response check as a bypass.

For zero-hint basis reconstruction, a justified work bound and failure policy would make implementations easier to compare. A cap needs an honest-input argument and consistent verification behavior; an empirical maximum from random curves is not a worst-case bound. Negative vectors for malformed encodings, singular coefficients, invalid kernel data, and failure propagation would help make these requirements concrete.

4 Checks and source material

The accompanying checks run with the Python standard library:

```
python3 scripts/audit_sqisign_v3_design.py
```

They passed exact enumeration of interval widths 1–512 at three draw widths, the three EIBox calculations, the illustrative lattice rejection, degree-9 kernel enumeration, degree-weight comparisons, and the small-field matrix count. These are arithmetic checks, not runs of a full signer or verifier.

The specification reviewed is v3.0, dated 1 September 2026 [1]. C source observations are pinned to commit [6d017708db40](#). For cross-reference with the longer working notes, *Biased interval sampling* is tracked as [SQI3-SPEC-01](#), and *Hint degree weighting* as [SQI3-PROOF-02](#).

References

- [1] SQIsign team. [SQIsign Specification, version 3.0](#), 1 September 2026. Sampler p. 28; bounded response sampling p. 51; basis hints p. 58; Figure 4 p. 104; stronger security and timing pp. 110–111.
- [2] SQIsign team. [Reference integer sampler](#), `src/mp/ref/lv1x/mp.c`, `ibz_rand_interval_with_domain`.
- [3] Aardal, Basso, De Feo, Patranabis, and Wesolowski. [A Complete Security Proof of SQIsign](#), IACR ePrint 2025/379, consulted version dated 1 August 2025, Section 5.6.
- [4] SQIsign team. [Reference verifier](#), `src/verification/ref/lv1x/verify.c`, `protocols_verify`.
- [5] SQIsign team. [Reference gluing validation](#), `src/hd/ref/lv1x/gluing.c`, `verify_two_torsion` and `gluing_compute`.